

LAPORAN FINAL TUGAS BESAR
KEAMANAN INFORMASI

Dosen Pengampu:

Adi Arga Arifnur, M.Kom



Anggun Meika Candra	2411521012
Zahra Aulia Nasution	2411521015
Talitha Nafisa Khairul	2411522007
Aldo Septia Elvawan	2411522013
Hana Rahmadini	2411523010

FAKULTAS TEKNOLOGI INFORMASI
PROGRAM STUDI SISTEM INFORMASI
UNIVERSITAS ANDALAS
TAHUN 2026

BAB V: HASIL EVALUASI KOMPONEN TATA KELOLA DSS05

Bab ini memaparkan hasil evaluasi menyeluruh terhadap seluruh komponen tata kelola COBIT 2019 yang berkaitan dengan domain DSS05 (Managed Security Services). Evaluasi dilakukan berdasarkan data wawancara dengan narasumber, observasi lapangan, serta analisis dokumen yang diperoleh selama proses penelitian.

Domain DSS05 berfokus pada perlindungan informasi enterprise untuk menjaga tingkat risiko keamanan informasi tetap berada dalam batas yang dapat diterima sesuai kebijakan keamanan perusahaan. Domain ini mencakup tujuh praktik manajemen, mulai dari perlindungan terhadap perangkat lunak berbahaya hingga pemantauan kerentanan infrastruktur secara aktif.

5.1 Komponen A: Process

Komponen Process mendefinisikan serangkaian praktik manajemen yang wajib dijalankan oleh organisasi untuk mengelola keamanan layanan (Managed Security Services) secara efektif. Ketujuh praktik manajemen DSS05 dievaluasi berikut ini berdasarkan tingkat kapabilitas aktivitas yang telah diimplementasikan.

1. DSS05.01 — Protect Against Malicious Software

DSS05.01 — Protect Against Malicious Software <i>Implementasi dan pemeliharaan langkah preventif, detektif, dan korektif terhadap perangkat lunak berbahaya di seluruh enterprise.</i>		
Metrik Contoh	Aktivitas Utama	Cap. Level
- Jumlah serangan malware yang berhasil - Persentase karyawan yang gagal uji phishing	1. Install & aktifkan proteksi malware pada semua fasilitas pemrosesan, dengan file definisi yang diperbarui otomatis. [Cap. Lvl 2]	Level 3 <i>Defined</i>

DSS05.01 — Protect Against Malicious Software

Implementasi dan pemeliharaan langkah preventif, detektif, dan korektif terhadap perangkat lunak berbahaya di seluruh enterprise.

	2. Filter traffic masuk (email, unduhan) untuk menangkai konten berbahaya seperti spyware dan phishing. 3. Komunikasikan kesadaran malware dan jalankan pelatihan berkala. [Cap. Lvl 3] 4. Distribusikan seluruh software proteksi secara terpusat melalui manajemen konfigurasi dan change management. 5. Tinjau secara rutin informasi ancaman baru dari advisory vendor keamanan. [Cap. Lvl 4]	
Temuan & Analisis Narasumber: <i>[DRAFT — Isi dengan hasil wawancara narasumber dan temuan observasi lapangan]</i>		Skor Aktual: __ / 5

[DRAFT — Tambahkan narasi hasil wawancara dan temuan observasi untuk DSS05.01]

2. DSS05.02 — Manage Network and Connectivity Security

DSS05.02 — Manage Network and Connectivity Security

Penggunaan langkah-langkah keamanan dan prosedur manajemen terkait untuk melindungi informasi di seluruh metode konektivitas.

Metrik Contoh	Aktivitas Utama	Cap. Level
• Jumlah pelanggaran firewall	1. Izinkan hanya perangkat terotorisasi mengakses jaringan; wajibkan autentikasi password. [Cap. Lvl 2]	Level 4 <i>Quantitatively Managed</i>

DSS05.02 — Manage Network and Connectivity Security

Penggunaan langkah-langkah keamanan dan prosedur manajemen terkait untuk melindungi informasi di seluruh metode konektivitas.

• Jumlah kerentanan yang ditemukan • Persentase downtime akibat insiden keamanan jaringan	2. Implementasikan mekanisme filter jaringan: firewall dan intrusion detection system (IDS). 3. Terapkan protokol keamanan jaringan yang sudah disetujui. 4. Konfigurasi perangkat jaringan secara aman. 5. Enkripsi informasi dalam transit sesuai klasifikasinya. [Cap. Lvl 3] 6. Tetapkan dan pelihara kebijakan keamanan konektivitas berdasarkan risk assessment. 7. Bangun mekanisme terpercaya untuk transmisi dan penerimaan informasi yang aman. 8. Lakukan penetration testing berkala. [Cap. Lvl 4] 9. Lakukan pengujian keamanan sistem secara berkala untuk memverifikasi kecukupan proteksi.	
Temuan & Analisis Narasumber: <i>[DRAFT— Isi dengan hasil wawancara narasumber dan temuan observasi lapangan]</i>		Skor Aktual: __ / 5

[DRAFT— Tambahkan narasi hasil wawancara dan temuan observasi untuk DSS05.02]

3. DSS05.03 — Manage Endpoint Security

DSS05.03 — Manage Endpoint Security <i>Memastikan endpoint (laptop, desktop, server, perangkat mobile) diamankan setidaknya sesuai persyaratan keamanan yang ditetapkan.</i>		
Metrik Contoh	Aktivitas Utama	Cap. Level
• Jumlah insiden yang melibatkan perangkat endpoint • Jumlah perangkat tidak terotorisasi yang terdeteksi • Persentase individu yang menerima pelatihan kesadaran endpoint	1. Konfigurasi sistem operasi secara aman. [Cap. Lvl 2] 2. Implementasikan mekanisme device lockdown. 3. Kelola remote access dan kontrol (perangkat mobile, telework). 4. Kelola konfigurasi jaringan secara aman. 5. Implementasikan filter traffic jaringan pada perangkat endpoint. 6. Lindungi integritas sistem. 7. Berikan perlindungan fisik pada perangkat endpoint. 8. Lakukan disposal perangkat endpoint secara aman. 9. Kelola akses berbahaya melalui email dan browser (blokir situs, nonaktifkan klik otomatis). 10. Enkripsi informasi yang tersimpan sesuai klasifikasinya. [Cap. Lvl 3]	Level 3 <i>Defined</i>
Temuan & Analisis Narasumber: <i>[DRAFT — Isi dengan hasil wawancara narasumber dan temuan observasi lapangan]</i>		Skor Aktual: ___ / 5

[DRAFT — Tambahkan narasi hasil wawancara dan temuan observasi untuk DSS05.03]

4. DSS05.04 — Manage User Identity and Logical Access

DSS05.04 — Manage User Identity and Logical Access

Memastikan semua pengguna memiliki hak akses informasi sesuai kebutuhan bisnis, terkoordinasi dengan unit bisnis.

Metrik Contoh	Aktivitas Utama	Cap. Level
• Rata-rata waktu antara perubahan dan pembaruan akun • Jumlah akun vs. jumlah pengguna terotorisasi • Jumlah insiden akses tidak sah ke informasi	1. Kelola hak akses pengguna berdasarkan prinsip least-privilege, need-to-have, need-to-know. [Cap. Lvl 2] 2. Administrasikan semua perubahan hak akses (buat, ubah, hapus) tepat waktu berdasarkan transaksi terotorisasi. [Cap. Lvl 3] 3. Segregasi, minimalkan, dan kelola akun pengguna istimewa (privileged accounts) secara aktif. 4. Identifikasi semua aktivitas pemrosesan informasi secara unik berdasarkan peran fungsional. 5. Autentikasi semua akses ke aset informasi berdasarkan peran individu atau aturan bisnis. 6. Pastikan semua pengguna (internal, eksternal, temporer) dapat diidentifikasi secara unik dalam sistem IT. 7. Pertahankan audit trail akses informasi sesuai sensitivitas dan persyaratan regulasi. [Cap. Lvl 4] 8. Lakukan review manajemen rutin terhadap semua akun dan hak istimewa terkait.	Level 4 <i>Quantitatively Managed</i>
Temuan & Analisis Narasumber: <i>[DRAFT — Isi dengan hasil wawancara narasumber dan temuan observasi lapangan]</i>		Skor Aktual: ___ / 5

[DRAFT — Tambahkan narasi hasil wawancara dan temuan observasi untuk DSS05.04]

5. DSS05.05 — Manage Physical Access to I&T Assets

DSS05.05 — Manage Physical Access to I&T Assets <i>Mendefinisikan dan mengimplementasikan prosedur untuk memberikan, membatasi, dan mencabut akses ke premises, gedung, dan area sesuai kebutuhan bisnis.</i>		
Metrik Contoh	Aktivitas Utama	Cap. Level
- Rata-rata rating penilaian keamanan fisik - Jumlah insiden keamanan informasi fisik	- Log dan pantau semua titik masuk ke situs IT; daftarkan semua pengunjung termasuk kontraktor. [Cap. Lvl 2] - Pastikan semua personel menampilkan identifikasi yang disetujui setiap saat. - Wajibkan pengunjung didampingi setiap saat saat berada di lokasi. - Batasi dan pantau akses ke situs IT sensitif dengan perimeter keamanan. - Kelola permintaan akses ke fasilitas komputasi secara terotorisasi. [Cap. Lvl 3] - Pastikan profil akses selalu diperbarui sesuai fungsi dan tanggung jawab pekerjaan. - Lakukan pelatihan kesadaran keamanan informasi fisik secara rutin.	Level 3 <i>Defined</i>
Temuan & Analisis Narasumber: <i>[DRAFT — Isi dengan hasil wawancara narasumber dan temuan observasi lapangan]</i>		Skor Aktual: __ / 5

[DRAFT — Tambahkan narasi hasil wawancara dan temuan observasi untuk DSS05.05]

6. DSS05.06 — Manage Sensitive Documents and Output Devices

DSS05.06 — Manage Sensitive Documents and Output Devices

Menetapkan pengamanan fisik, praktik akuntansi, dan manajemen inventaris yang tepat terhadap aset I&T sensitif seperti formulir khusus, printer, dan token keamanan.

Metrik Contoh	Aktivitas Utama	Cap. Level
- Jumlah perangkat output yang dicuri - Persentase dokumen sensitif dan perangkat output yang teridentifikasi dalam inventaris	- Tetapkan prosedur untuk menerima, menggunakan, memindahkan, dan membuang dokumen sensitif dan perangkat output. [Cap. Lvl 2] - Pastikan kontrol kriptografi tersedia untuk melindungi informasi sensitif yang tersimpan secara elektronik. - Tetapkan hak akses ke dokumen dan perangkat output sensitif berdasarkan prinsip least-privilege. [Cap. Lvl 3] - Buat inventaris dokumen sensitif dan perangkat output; lakukan rekonsiliasi secara berkala. - Tetapkan pengamanan fisik yang memadai atas dokumen sensitif.	Level 3 <i>Defined</i>
Temuan & Analisis Narasumber: [DRAFT— Isi dengan hasil wawancara narasumber dan temuan observasi lapangan]		Skor Aktual: __ / 5

[DRAFT — Tambahkan narasi hasil wawancara dan temuan observasi untuk DSS05.06]

7. DSS05.07 — Manage Vulnerabilities and Monitor Infrastructure

DSS05.07 — Manage Vulnerabilities and Monitor Infrastructure for Security Events <i>Menggunakan portofolio tools untuk mengelola kerentanan dan memantau infrastruktur dari akses tidak sah; integrasi dengan event monitoring dan incident management.</i>		
Metrik Contoh	Aktivitas Utama	Cap. Level
- Jumlah pengujian kerentanan pada perangkat perimeter - Jumlah kerentanan yang ditemukan saat pengujian - Waktu yang dibutuhkan untuk remediasi kerentanan - Persentase tiket yang dibuat tepat waktu saat sistem identifikasi insiden potensial	- Gunakan portofolio teknologi (vulnerability scanner, fuzzer, sniffer, protocol analyzer) untuk identifikasi kerentanan. [Cap. Lvl 2] - Definisikan dan komunikasikan skenario risiko agar mudah dikenali dengan pemahaman likelihood dan impact. - Tinjau event log secara berkala untuk mendeteksi insiden potensial. - Pastikan tiket insiden terkait keamanan dibuat tepat waktu ketika monitoring mendeteksi insiden potensial. - Log event keamanan dan simpan rekaman untuk periode yang sesuai. [Cap. Lvl 3]	Level 4 <i>Quantitatively Managed</i>
Temuan & Analisis Narasumber: <i>[DRAFT— Isi dengan hasil wawancara narasumber dan temuan observasi lapangan]</i>		Skor Aktual: __ / 5

[DRAFT— Tambahkan narasi hasil wawancara dan temuan observasi untuk DSS05.07]

5.2 Komponen B: Organizational Structures

Komponen Organizational Structures mengidentifikasi struktur tata kelola dan pembagian peran serta tanggung jawab dalam pengelolaan keamanan layanan. Berdasarkan kerangka COBIT 2019, tabel RACI berikut menggambarkan pemetaan tanggung jawab (Accountable/Responsible) untuk setiap praktik manajemen DSS05.

Kode	Praktik Manajemen	CIO	CISO	BPO	HR	Head Dev	Head IT Ops	IS Mgr	Privacy Officer
DSS05.01	Protect against malicious software	A	R	R	R	R	R		
DSS05.02	Manage network and connectivity security	A	R				R	R	
DSS05.03	Manage endpoint security	A	R				R	R	
DSS05.04	Manage user identity and logical access	A	R	R			R	R	
DSS05.05	Manage physical access to I&T assets	A	R				R	R	
DSS05.06	Manage sensitive documents and output devices	A	R					R	

Kode	Praktik Manajemen	CIO	CISO	BPO	HR	Head Dev	Head IT Ops	IS Mgr	Privacy Officer
DSS05.07	Manage vulnerabilities and monitor infra	A	R				R	R	

Keterangan: A = Accountable (bertanggung jawab atas keputusan akhir), R = Responsible (bertanggung jawab atas pelaksanaan). CIO = Chief Information Officer; CISO = Chief Information Security Officer; BPO = Business Process Owners; IS Mgr = Information Security Manager.

Berdasarkan tabel RACI di atas, CISO memiliki peran Responsible di seluruh tujuh praktik manajemen DSS05, sementara CIO memegang peran Accountable. Hal ini mencerminkan kejelasan kepemilikan kebijakan keamanan di tingkat eksekutif.

[DRAFT — Isi dengan analisis struktur organisasi aktual dari hasil wawancara narasumber dan bandingkan dengan RACI COBIT 2019]

5.3 Komponen C: Information Flows and Items

Komponen Information Flows and Items mengidentifikasi dokumen, data, dan artefak yang menjadi input maupun output dari setiap praktik manajemen DSS05. Pemahaman alur informasi ini penting untuk memastikan kesinambungan dan konsistensi pengendalian keamanan di seluruh proses.

Kode	Input (Dari)	Output	Output Menuju
DSS05.01	—	Malicious software prevention policy; Evaluations of potential threats	APO01.02; APO12.02; APO12.03
DSS05.02	APO01.07 (Data classification); APO09.03 (SLAs)	Connectivity security policy; Results of penetration tests	APO01.02; MEA04.07
DSS05.03	APO03.02 (Infra model); APO09.03 (SLAs/OLAs); BAI09.01 (Inventory)	Security policies for endpoint devices	APO01.02
DSS05.04	APO01.05 (Roles & responsibilities); APO03.02 (Infra model)	Results of user account reviews; Approved user access rights	Internal
DSS05.05	DSS06.03 / MEA04.07 (Access logs)	Approved access requests	Internal

Kode	Input (Dari)	Output	Output Menuju
DSS05.06	APO03.02 (Infra model)	Access privileges; Inventory of sensitive documents & devices	Internal
DSS05.07	—	Security incident tickets; Security incident characteristics; Security event logs	DSS02.02; Internal

[DRAFT — Isi dengan gambaran alur informasi aktual yang digunakan oleh organisasi (misalnya sistem dokumentasi, platform komunikasi, dll.) berdasarkan hasil wawancara]

5.4 Komponen D: People, Skills and Competencies

Komponen People, Skills and Competencies mendefinisikan keahlian yang harus dimiliki oleh sumber daya manusia yang terlibat dalam pengelolaan keamanan informasi. COBIT 2019 mengidentifikasi tiga kompetensi inti yang relevan dengan domain DSS05:

Information Security	Keahlian dalam merancang, mengimplementasikan, dan mengelola kebijakan serta kontrol keamanan informasi secara menyeluruh. Referensi: SFIA V6 (SCTY).
Information Security Management	Kemampuan mengelola fungsi keamanan informasi pada level manajerial, termasuk perencanaan strategis, penilaian risiko, dan kepatuhan regulasi. Referensi: e-CF Framework (E.8).
Penetration Testing	Keahlian teknis untuk melakukan pengujian keamanan ofensif guna mengidentifikasi kerentanan sebelum dapat dieksploitasi oleh pihak tidak bertanggung jawab. Referensi: SFIA V6 (PENT).
Security Administration	Kemampuan operasional dalam mengelola kontrol akses, memantau sistem, dan merespons insiden keamanan sehari-hari. Referensi: SFIA V6 (SCAD).

[DRAFT — Isi dengan penilaian aktual kompetensi SDM di organisasi berdasarkan hasil wawancara (pelatihan yang ada, sertifikasi yang dimiliki tim, gap kompetensi yang ditemukan)]

5.5 Komponen E: Policies and Procedures

Komponen Policies and Procedures mengidentifikasi kebijakan dan prosedur formal yang harus ada dan ditegakkan untuk mendukung implementasi DSS05 secara efektif. COBIT 2019 menetapkan satu kebijakan utama yang menjadi fondasi seluruh praktik manajemen domain ini:

Nama Kebijakan	Information Security Policy
Deskripsi	Kebijakan yang menetapkan panduan untuk melindungi informasi perusahaan beserta sistem dan infrastruktur yang terkait.
Cakupan	Seluruh aset informasi, sistem, infrastruktur, dan pengguna (internal, eksternal, dan temporer) yang berinteraksi dengan lingkungan IT perusahaan.
Status di Organisasi	[DRAFT — Isi dengan status implementasi kebijakan aktual dari hasil wawancara]
Dokumen Terkait Lainnya	[DRAFT — Isi dengan daftar dokumen SOP, prosedur, atau panduan teknis lain yang ditemukan]

[DRAFT — Tambahkan narasi evaluasi terhadap kelengkapan, kekinian, dan penegakan kebijakan keamanan informasi di organisasi]

5.6 Komponen F: Culture, Ethics and Behavior

Komponen Culture, Ethics and Behavior mengevaluasi sejauh mana budaya keamanan informasi telah tertanam dalam perilaku sehari-hari seluruh anggota organisasi. COBIT 2019 menekankan satu elemen budaya kunci yang menjadi fondasi keberhasilan implementasi DSS05:

Elemen Budaya Utama	Menciptakan budaya kesadaran (culture of awareness) terkait tanggung jawab pengguna dalam memelihara praktik keamanan dan privasi.
Referensi Standar	HITRUST CSF v9 (01.03 User Responsibilities); ISF Standard of Good Practice 2016 (PM2.1 Security Awareness Program)

Budaya keamanan yang kuat tidak dapat dibangun hanya melalui kebijakan tertulis, melainkan harus diwujudkan melalui program-program konkret yang bersifat berkelanjutan dan terukur. Beberapa indikator budaya keamanan yang positif meliputi:

- Pelaksanaan security awareness training secara wajib dan berkala untuk seluruh karyawan.
- Program simulasi phishing untuk menguji dan meningkatkan kewaspadaan karyawan.
- Kebiasaan proaktif tim produk dalam berkonsultasi dengan tim keamanan sebelum meluncurkan fitur baru.
- Pelaporan insiden keamanan yang aktif oleh karyawan tanpa rasa takut terhadap sanksi.

[DRAFT — Isi dengan penilaian aktual budaya keamanan di organisasi berdasarkan hasil wawancara dan observasi]

5.7 Komponen G: Services, Infrastructure and Applications

Komponen Services, Infrastructure and Applications mengidentifikasi layanan, infrastruktur teknis, dan aplikasi yang dibutuhkan untuk mendukung implementasi seluruh praktik manajemen DSS05. COBIT 2019 menetapkan delapan kategori layanan dan teknologi keamanan inti berikut:

Directory Services	Layanan direktori terpusat untuk mengelola identitas pengguna, perangkat, dan kebijakan akses dalam jaringan (contoh: Active Directory, LDAP).
Email Filtering Systems	Sistem penyaringan email untuk mendeteksi dan memblokir email berbahaya (phishing, spam, malware) sebelum mencapai kotak masuk pengguna.
Identity and Access Management (IAM)	Platform terpadu untuk mengelola siklus hidup identitas pengguna dan hak akses, termasuk provisioning dan de-provisioning akun.
Security Awareness Services	Layanan atau platform yang digunakan untuk menjalankan program pelatihan kesadaran keamanan, termasuk modul e-learning dan simulasi serangan.
SIEM Tools	Security Information and Event Management — platform untuk mengumpulkan, mengkorelasikan, dan menganalisis log keamanan dari berbagai sumber secara terpusat.
SOC Services	Security Operations Center — tim dan infrastruktur yang beroperasi 24/7 untuk memantau, mendeteksi, dan merespons insiden keamanan secara real-time.

Third-Party Security Assessment Services	Layanan dari pihak eksternal (seperti konsultan keamanan atau penguji penetrasi independen) untuk melakukan audit dan penilaian keamanan secara objektif.
URL Filtering Systems	Sistem yang memfilter akses web berdasarkan kategori URL untuk mencegah akses ke situs berbahaya atau tidak sesuai kebijakan perusahaan.

[DRAFT — Petakan tools dan infrastruktur keamanan aktual yang digunakan organisasi ke dalam kategori di atas berdasarkan hasil wawancara]

BAB VI: ANALISIS TEMUAN AUDIT & PENILAIAN CAPABILITY LEVEL DSS05

Bab ini menyajikan hasil analisis temuan audit secara kuantitatif dan kualitatif, mencakup penilaian tingkat kapabilitas (capability level) untuk setiap praktik manajemen DSS05, serta analisis kesenjangan (gap analysis) yang menggabungkan hasil evaluasi domain DSS05 dan APO13.

1. 6.2 Matriks Capability Level DSS05

Penilaian tingkat kapabilitas dilakukan berdasarkan kriteria capability level COBIT 2019, dengan skala penilaian dari Level 1 (Initial) hingga Level 5 (Optimizing). Skor dan level berikut merupakan estimasi awal yang perlu diverifikasi dan disesuaikan berdasarkan hasil aktual wawancara dengan narasumber.

Kode	Praktik Manajemen	Skor As-Is	Level As-Is	Skor To-Be	Level To-Be	Catatan Gap
DSS05.01	Protect against Malicious Software	?	Managed/Defined	3–4	Defined / Quant. Managed	[DRAFT]
DSS05.02	Manage Network & Connectivity Security	?	Managed/Defined	4	Quantitatively Managed	[DRAFT]
DSS05.03	Manage Endpoint Security	?	Managed/Defined	3–4	Defined / Quant. Managed	[DRAFT]
DSS05.04	Manage User Identity & Logical Access	?	Defined	4	Quantitatively Managed	[DRAFT]
DSS05.05	Manage Physical Access to I&T Assets	?	Managed/Defined	3	Defined	[DRAFT]

Kode	Praktik Manajemen	Skor As-Is	Level As-Is	Skor To-Be	Level To-Be	Catatan Gap
DSS05.06	Manage Sensitive Documents & Output Dev.	?	Managed	3	Defined	[DRAFT]
DSS05.07	Manage Vulnerabilities & Monitor Infra	?	Managed/Defined	4	Quantitatively Managed	[DRAFT]

Catatan: Kolom 'Skor As-Is' dan 'Skor To-Be' menggunakan skala 1–5 yang disesuaikan dengan skala pertanyaan wawancara. Kolom 'Catatan Gap' berisi potensi area perbaikan yang teridentifikasi.

[DRAFT — Sesuaikan seluruh angka skor dan level dengan hasil aktual wawancara narasumber sebelum finalisasi laporan]

2. 6.3 Gap Analysis Gabungan (APO13 + DSS05)

Gap analysis berikut merangkum kesenjangan antara kondisi aktual (As-Is) dan target ideal (To-Be) untuk seluruh domain yang dievaluasi dalam penelitian ini, yaitu APO13 (Managed Security) dan DSS05 (Managed Security Services). Analisis ini menjadi dasar penyusunan rekomendasi perbaikan pada Bab VII.

Domain	As-Is	To-Be	Gap	Rekomendasi Penutup Gap
DSS05.01	Level ?	Level 3–4	?	<i>[DRAFT — Isi rekomendasi penutup gap DSS05.01]</i>
DSS05.02	Level ?	Level 4	?	<i>[DRAFT — Isi rekomendasi penutup gap DSS05.02]</i>
DSS05.03	Level ?	Level 3–4	?	<i>[DRAFT — Isi rekomendasi penutup gap DSS05.03]</i>

Domain	As-Is	To-Be	Gap	Rekomendasi Penutup Gap
DSS05.04	Level ?	Level 4	?	<i>[DRAFT — Isi rekomendasi penutup gap DSS05.04]</i>
DSS05.05	Level ?	Level 3	?	<i>[DRAFT — Isi rekomendasi penutup gap DSS05.05]</i>
DSS05.06	Level ?	Level 3	?	<i>[DRAFT — Isi rekomendasi penutup gap DSS05.06]</i>
DSS05.07	Level ?	Level 4	?	<i>[DRAFT — Isi rekomendasi penutup gap DSS05.07]</i>
APO13.01	Level 3	Level 4	+1	Formalisasi KPI ISMS dan integrasikan ke dashboard manajemen berkala.
APO13.02	Level 4	Level 4	0	Pertahankan risk assessment di Design Phase; perkuat otomatisasi risk register.
APO13.03	Level 4	Level 5	+1	Tingkatkan otomatisasi eskalasi insiden dan continuous improvement berbasis Datadog.

[DRAFT — Lengkapi kolom 'As-Is', 'Gap', dan 'Rekomendasi' untuk DSS05.01–DSS05.07 setelah wawancara dilaksanakan]

BAB VII: PENUTUP

3. 7.1 Kesimpulan Akhir Audit Keamanan Informasi

Penelitian ini telah melakukan evaluasi komprehensif terhadap implementasi tata kelola keamanan informasi pada objek penelitian berdasarkan dua domain utama COBIT 2019: APO13 (Managed Security) dan DSS05 (Managed Security Services). Melalui pendekatan wawancara eksplorasi kualitatif dan penilaian skala kuantitatif, kelompok berhasil memetakan kondisi aktual pengelolaan keamanan informasi dan membandingkannya dengan standar kapabilitas yang ditetapkan.

Secara keseluruhan, hasil evaluasi menunjukkan bahwa organisasi yang diteliti telah menjalankan praktik keamanan informasi pada tingkat yang cukup matang. Kebijakan dan prosedur formal telah tersedia, struktur organisasi keamanan informasi telah terdefinisi dengan jelas, dan berbagai kontrol teknis telah diimplementasikan untuk melindungi aset informasi dari ancaman yang relevan.

Namun demikian, terdapat beberapa area yang masih memiliki ruang perbaikan, terutama dalam hal formalisasi metrik kinerja (KPI) yang terukur, peningkatan otomatisasi proses keamanan, serta penguatan program kesadaran keamanan di tingkat operasional.

[DRAFT — Sesuaikan paragraf kesimpulan dengan temuan aktual wawancara dan skor capability level yang sudah diverifikasi]

4. 7.2 Rekomendasi Akademik dan Saran Perbaikan Masa Depan

Berdasarkan hasil gap analysis yang telah dilakukan, kelompok merumuskan rekomendasi akademik berikut sebagai saran perbaikan untuk meningkatkan kematangan tata kelola keamanan informasi:

R-01

Otomatisasi pembaruan definisi proteksi malware dan integrasi threat intelligence feed real-time untuk meningkatkan kemampuan deteksi ancaman terkini (DSS05.01).

R-02	Lakukan penetration testing secara berkala dengan melibatkan pihak ketiga yang independen untuk memvalidasi keamanan jaringan secara objektif (DSS05.02).
R-03	Perkuat manajemen perangkat endpoint dengan solusi Mobile Device Management (MDM) terpusat, terutama untuk perangkat yang digunakan dalam skema kerja jarak jauh (DSS05.03).
R-04	Implementasikan Privileged Access Management (PAM) yang lebih ketat disertai monitoring real-time terhadap seluruh aktivitas akun istimewa (DSS05.04).
R-05	Lakukan audit keamanan fisik secara berkala dan integrasikan sistem kontrol akses fisik dengan sistem logging terpusat untuk meningkatkan visibilitas dan akuntabilitas (DSS05.05).
R-06	Digitalisasi inventaris dokumen sensitif dan terapkan data loss prevention (DLP) tools untuk memonitor perpindahan data sensitif secara proaktif (DSS05.06).
R-07	Kembangkan kapabilitas Security Operations Center (SOC) dengan mengintegrasikan SIEM tools dan otomatisasi respons insiden (SOAR) untuk mempercepat deteksi dan mitigasi ancaman (DSS05.07).
R-08	Formalisasi KPI ISMS dan integrasikan ke dalam laporan manajemen berkala agar pimpinan dapat memantau performa keamanan secara real-time (APO13.01).
R-09	Kembangkan mekanisme continuous improvement berbasis data historis insiden untuk mendorong evolusi sistem keamanan menuju Level 5 — Optimizing (APO13.03).

Rekomendasi di atas bersifat akademik dan disusun berdasarkan referensi kerangka kerja COBIT 2019, ISO/IEC 27001, serta best practice industri keamanan informasi. Implementasi rekomendasi disesuaikan dengan prioritas dan kapasitas sumber daya organisasi.

DAFTAR PUSTAKA

ISACA. (2018). COBIT 2019 Framework: Governance and Management Objectives. Rolling Meadows, IL: ISACA.

ISACA. (2018). COBIT 2019 Framework: Introduction and Methodology. Rolling Meadows, IL: ISACA.

ISACA. (2019). COBIT 2019 Design Guide: Designing an Information and Technology Governance Solution. Rolling Meadows, IL: ISACA.

International Organization for Standardization. (2022). ISO/IEC 27001:2022 — Information Security, Cybersecurity and Privacy Protection. Geneva: ISO.

International Organization for Standardization. (2013). ISO/IEC 27002:2013 — Code of Practice for Information Security Controls. Geneva: ISO.

National Institute of Standards and Technology. (2017). Special Publication 800-53 Rev. 5 (Draft): Security and Privacy Controls for Information Systems and Organizations. Gaithersburg, MD: NIST.

HITRUST Alliance. (2017). HITRUST CSF Version 9. Frisco, TX: HITRUST.

Information Security Forum. (2016). The Standard of Good Practice for Information Security. London: ISF.

[DRAFT — Tambahkan referensi jurnal, artikel, atau sumber lain yang digunakan kelompok]

LAMPIRAN

5. Lampiran A — Instrumen Borang Wawancara DSS05

Instrumen borang wawancara yang digunakan untuk mengevaluasi domain DSS05 mencakup pertanyaan skala kuantitatif (1–5) dan pertanyaan kualitatif eksploratif untuk setiap praktik manajemen DSS05.01 hingga DSS05.07, beserta pertanyaan evaluasi komponen B hingga G.

[DRAFT — Sisipkan file borang wawancara DSS05 yang telah diisi (screenshot/scan) di sini]

6. Lampiran B — Bukti Dokumentasi & Foto Penelitian

[DRAFT — Sisipkan screenshot borang wawancara yang sudah diisi, foto sesi wawancara, atau dokumentasi pendukung lainnya di sini]